SAVEETHA

INSTITUTE OF MEDICAL AND TECHNICAL SCIENCES
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

Programme: **B.E / B.Tech**

Course Code: **ITA1439**

Course Name: **Ethical Hacking**

Duration: **1: 30 Hr**

Date: **02-11-2026**

39/50

88%

Max Marks: **50 Marks**

CONTINUOUS INTERNAL ASSESSMENT 1

Course Outcomes
On successful completion of the course, students will be able to:

CO	Course Outcome Statement
CO1	Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.
CO2	Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Answer all the Questions

1. A private bank hires a security firm to test its internet-banking portal before launch. In the same month, a former employee uses old credentials to view customer records, a student runs a downloaded attack tool against the portal "to see what happens", and an activist group defaces the bank's website. Define the term hacker and classify each person or group, including the hired testers, as white hat, black hat, grey hat, script kiddie, hacktivist or insider, with reasons. Explain the ethical principles the testers must follow, such as written authorization, agreed scope, confidentiality, avoiding harm and honest reporting. **(CO1) (BL3)**

2. A student finds an SQL injection flaw in the e-learning portal of another university that exposes the marks and contact details of about 20,000 students, without having permission to test it. The student is considering posting the details on social media, reporting privately to the university, or offering the details in exchange for payment. Analyze the legal position of the student under the Information Technology Act, 2000, with reference to unauthorized access and data theft. Compare full disclosure, responsible (coordinated) disclosure and bug-bounty programmes, and recommend the most appropriate disclosure process and timeline for this case with justification. **(CO1) (BL4)**

3. (a) A college authorizes its security club to carry out a penetration test of the student portal. Before any testing begins, the team must define how the engagement will be conducted. Apply the ethical hacking methodology by listing its phases — reconnaissance, scanning, gaining access, maintaining access and reporting — and state the objective of each phase. Explain what a written rules-of-engagement / authorization document must specify (in-scope targets, time window, permitted and prohibited techniques, and the point of contact) to keep the engagement lawful, in-scope and non-destructive. **(CO1) (BL3) (5 Marks)**

(b) A security team is authorized to assess the internet exposure of a retail company that uses the domain retailco.example. Explain the difference between passive and active footprinting, and describe how the team would use WHOIS lookups, nslookup or dig, and search-engine operators (site:, filetype:, intitle:) to collect information about the company. For any THREE of these sources, state one item of information it may reveal and the security risk it creates. **(CO2) (BL3) (5 Marks)**

4. During an authorized assessment, a tester runs "dig axfr example.com @ns1.example.com" and the name server returns the full zone, including www (A, 203.0.113.10), vpn (A, 203.0.113.25), hr-portal (A, 10.10.5.20), dev-db (A, 10.10.8.15), mail (MX, priority 10) and a TXT record listing the SPF mail servers. Explain how a DNS zone transfer works and why it is meant only between primary and secondary name servers. Analyze what an attacker could learn from each record to plan further attacks, and recommend countermeasures such as restricting transfers, TSIG authentication and split-horizon DNS. **(CO2) (BL4)**

5. An organization receives an e-mail that appears to come from its IT help desk, asking employees to "verify" their passwords through a link. Later, a caller claiming to be from the help desk asks the accounts section for a one-time password, and a visitor without an ID card follows an employee through a secured door. Identify each attack type (phishing, vishing, pretexting or tailgating) and the psychological principles used, such as authority and urgency. Describe how an authorized social engineering assessment of this organization should be planned, and propose technical, procedural and awareness-based countermeasures. **(CO2) (BL3)**

TA1439

A. Manoj Reddy
192311171

CONTINUOUS INTERNAL ASSESSMENT-1

4.

Hacker:

A hacker is a person who uses technical knowledge and computer skills to identify, analyse, access or modify computer systems, networks and applications.

- Hackers may work to improve security or exploit vulnerabilities for unauthorized purposes.

A. Calassification of Hackers:

1. White hat hacker:

- White hat hackers are authorized security Professionals who identify vulnerabilites in computer Systems.

2. Black hat hacker

- Black hat hackers gain unauthorized access to computer systems.
- They may steal information, damage systems.

3. Grey hat hacker:

- Grey hat hackers identify security vulnerabilities without obtaining prior permision.
- They may not intend to cause damage or steal information.

4. Script kiddie:

- A script kiddie is an inexperinced person who uses the confidential data.

5. Hacktivist:-

- Hacktivist use hacking techniques to promote political social or ideological causes.
- Their activities may include website defacement, data leaks and denial-of-service attacks.

6. Insider:-

- An insider is an employee, former employee or contractor who has legitimate or previous access to an organization in formation.

C. Ethical principles followed by security testers:-

The Security firm hired by the bank must follow these ethical principles:

1. written Authorization
2. Agreed Scope
3. Confidentiality
4. Avoid Harm
5. Honest Reporting
6. Responsible Disclosure.

2. SQL Injection:- SQL Injection is a web application vulnerability in which an attacker manipulates SQL queries through specially crafted input.

In this scenario, a student discovers a vulnerability that exposes information without authorization.

Legal Position Under IT Act, 2000:

1. Section 43: Covers unauthorized access, downloading, copying or extracting data from computer systems.

2. Section 66: Applies when acts covered under section 43 are committed dishonestly or fraudulently.

3. Section 72: Deals with breach of confidentiality and privacy under specified statutory conditions.

4. Section 72A: Deals with disclosure of personal information in breach of a lawful contract.

Three disclosure methods:

1. full disclosure:
   * publishing vulnerability details publicly
   * Anyone can see the information.

2. Responsible Disclosure:
   * inform the University privately
   * Give time to fix the vulnerability

3. Bug Bounty:
   * Organizations invite security researchers
   * Testing must follow programme rules
   * Only authorized targets are allowed.

(3) Ethical hacking:-

(A) Ethical hacking is the process of testing computer systems with permission to identify security weakness and protect them from attackers.

Five phases of ethical hacking:-

1. Reconnaissance:
   Collect information about the target. Such as domain names, IP addresses and organization. details.

2. scanning: Identify active systems, oper ports, runing services and vulnerabilities.

3. Gaining Acces: Test identified vulnerabilities to check whether unauthorized acces is possible.

4. Maintaining Acces:
   Evaluate whether an attacker could keep acces to a compromised system. Ethical testers must not install unauthorized back doors.

5. Reporting:
   Prepare a report containing vulnerabilities, risks, evidence and solutions.

Rules:-
- Inscope Targets
- Time window
- Permitted Tchniques
- Prohibited techniques
- Point of contact.

Foot printing:- Foot printing is the proces of collecting information about an organization before performing security testing.

Types:-

1. passive footprinting: collecting information without directly interacting with target systems.

2. Active footPrinting: Directly interacting with target systems to collect information.

Information -gathering tools: WHOIS, nslookup, dig, Google Search.

4. DNS:- Domain name system. It converts domain names into IP addresses. DNS zone transfer is the proces of copying DNS records from a primary DNS server.

Types of DNS zone transfer:-

1. AXFR : Transfers the complete DNS zone.
2. IXFR : Transfers only the changed DNS records.

Working of DNS zone transfer.

1. Primary DNS server stores original DNS records.
2. Secondary DNS server sends a zone transfer request.
3. Primary server verifies the request
4. DNS records are transferred.

5. Social Engineering: Social Engineering is an attack in which attackers manipulate people to obtain confidential information.

Types of social engineering attacks:-

1. Phishing: Sending fake emails to steal Passwords or Personal information.

2. Vishing: Using telephone calls to steal confidential information.

3. Pretexting: Creating a false identity or story to gain trust.

4. Tailgating: Entering a restricted area by following an authorized employee without Permission.

Psychological principles:

1. Authority: Pretending to be a manager or IT administrator.

2. Urgency: Creating an emergency to force quick suspension

3. Trust: Pretending to be a trusted person.

4. Fear: Threatening employees with account suspension.